Responsible AI Framework:
Data Privacy, Security, IP, and Regulatory Compliance

NovaCare Health Systems

Course: Responsible Appl of AI (AIML-510-01R4A)

Assignment: 4.4 RAI Framework Project: Privacy, Security, IP, and Compliance

Arshi Khan

Date: September 20, 2026

NovaCare Health Systems

Fictional healthcare enterprise (consistent with Assignments 1.3 and 1.4)

- **Scale** — 30 hospitals, 150+ outpatient facilities, approximately 45,000 employees
- **Reach** — Serves about 6 million patients annually through hospitals, clinics, diagnostic centers, and telehealth
- **Technology footprint** — Enterprise EHR, cloud analytics, imaging, patient portals, and digital care platforms
- **RAI foundation** — Seven ethical principles established in 1.3, operationalized through the NIST AI RMF (Govern, Map, Measure, Manage) in 1.4

AI Use Cases Under Consideration

Same four use cases established in Assignment 1.3

1

AI-Assisted Medical Imaging

Detects abnormalities in X-rays, CT scans, and MRIs

2

Patient Deterioration Prediction

Predicts patients at risk of rapid clinical decline

3

Generative AI Clinical Assistant

Summarizes records and drafts clinical documentation

4

AI Scheduling & Resource Optimization

Forecasts demand and optimizes staffing and appointments

Chart: Data Privacy Protection Level by Use Case

Use Case	Privacy Level	Justification / Threshold
AI-Assisted Medical Imaging	High	*De-identification per HIPAA Safe Harbor (all 18 identifiers removed) before research use; re-identification requires explicit patient consent; access reviewed monthly*
Patient Deterioration Prediction	High	*Full PHI encryption at rest/in transit (AES-256); access limited to care-team members with active need; retention capped at treatment period plus 6 years per HIPAA*
Generative AI Clinical Assistant	High-Moderate	*Zero training retention on real patient notes; PHI redacted from logs within 24 hours; patients notified that AI drafts documentation*
AI Scheduling & Resource Optimization	Low-Moderate	*Aggregated, de-identified data only; no individual patient identifiers needed for staffing forecasts*

Chart: Data Security Practices by Use Case

Use Case	Security Practices	Measurable Standard
AI-Assisted Medical Imaging	Encrypted PACS storage, full access audit trail	*100% of image-access events logged; quarterly penetration testing*
Patient Deterioration Prediction	EHR network segmentation, anomaly detection	*Alert triggers on any single query pulling more than 50 patient records; vendors must hold SOC 2 Type II certification*
Generative AI Clinical Assistant	Prompt/output sandboxing; no external API calls carrying PHI	*Zero PHI leaves NovaCare's private cloud boundary; monthly red-team test for prompt injection*
AI Scheduling & Resource Optimization	Standard cloud security controls	*Annual security audit; access rights reviewed quarterly*

Chart: Intellectual Property Considerations by Use Case

Use Case	IP Consideration	Mitigation
AI-Assisted Medical Imaging	Vendor model IP and liability for diagnostic errors	*Contractual indemnification from imaging AI vendors (per WIPO checklist); clear ownership of any fine-tuned weights*
Patient Deterioration Prediction	Training data provenance (internal EHR data)	*Data-use rights confirmed via Notice of Privacy Practices; no third-party training data ownership disputes*
Generative AI Clinical Assistant	AI-drafted notes become part of the legal medical record	*Clinician review/edit constitutes sufficient human authorship for institutional ownership of the final note*
AI Scheduling & Resource Optimization	Low IP risk; operational, non-creative output	*Standard vendor licensing terms are sufficient*

Chart: US vs. EU Regulatory Compliance Actions

Grounded in the Stanford AI Index 2025, Chapter 6 (Policy and Governance)

Requirement Area	United States	European Union
Governing Framework	Sectoral and agency-driven (HIPAA, FTC Act, state AI laws); no single comprehensive federal AI law	*EU AI Act: comprehensive, risk-tiered, binding across all 27 member states; healthcare AI is classified high-risk*
Compliance Action Required	Conduct HIPAA risk assessment; monitor state AI legislation (131 state laws passed in 2024 alone) in every state NovaCare operates	*Complete a conformity assessment before market entry; register high-risk systems in the EU database*
Enforcement Penalty	HIPAA penalties up to $2.1M per violation category, per year	*Up to 6% of global annual turnover for high-risk AI Act violations*
Ongoing Obligation	Breach notification within 60 days (HIPAA)	*Continuous post-market monitoring and incident reporting for high-risk systems*

Conclusion

Difficulties and open questions from this workshop

- Drawing the line for "moderate" privacy protection (scheduling use case) felt more like judgment than a clean rule.
- The US and EU need genuinely separate compliance tracks, not one framework with small tweaks. Sectoral vs. binding risk-tiered are very different starting points.
- For the AI clinical assistant, "ownership" doesn't even feel like the right question to ask about a medical record.
- Vallor's point on consent stuck with me: explaining AI's role in plain language risks becoming another wall of text nobody reads.

Open question: if full informed consent isn't realistic, is just disclosing AI use enough to call it ethical?

References

- Stanford HAI. (2025). Artificial Intelligence Index Report 2025, Chapter 6: Policy and Governance.

- Vallor, S. (n.d.). An Introduction to Data Ethics. Markkula Center for Applied Ethics, Santa Clara University.